Privacy and security note

Built to the Digital Personal Data Protection Act, 2023 and the DPDP Rules, 2025.
The data is synthetic; we treat it as real.

Dukaan Connect
Airtel SYNC, Track A

Step	What we collect	Why we need it
Advisor	Business type, staff, sites, city, pin code; GSTIN if the owner offers it	Pick an eligible bundle; the GSTIN fills the business details from the registry
Order	Mobile number	Order updates and the SIM-swap check on the signatory
KYC	GSTIN, Udyam number, four document photos; from the ID only name, ID number and validity	Verify the business and the person signing

Never collected: Aadhaar number, face images, date of birth, bank details (UPI handles payment).

`GSTIN 37LDYXK0296F1ZB` at the API becomes `tok_gstin_k3Q9...` everywhere else; people see `37LD********1ZB`

Consent before processing

A standalone notice in the owner's language with one switch per purpose: verify my business, and install and bill (both needed); updates about this order, and offers (optional; offers off by default). Each choice is stored with notice version, time and channel. Withdrawing takes one tap in the tracker. Nothing is uploaded or detokenised for a purpose without a live consent for it.

Tokens in transit

Orders, tracker, back-office, analytics and the language model see only tokens or masked values. Only Smart KYC and fulfilment may detokenise, each for its own purpose, and every attempt, allowed or refused, is written to the audit log. A keyed hash (HMAC-SHA256) supports lookups and duplicate checks without the raw value.

Encryption at rest

AES-256-GCM envelope encryption: every vault entry and every document has its own data key, wrapped by a key derived from a master key held in Secret Manager or KMS. Databases and buckets hold only ciphertext. TLS on every hop.

The AI boundary

The language model receives masked text and registry results, never a raw GSTIN, phone number or document. OCR runs on our own servers (Tesseract), so documents never reach a third-party AI service. The model cannot set products or prices; a guard checks every reply.

Who sees what

The owner sees everything about their own order. Partners see business name, city, stall reason and score, and call through a masked virtual number. Reviewers see masked identifiers and the failed checks. Engineers see masked logs: a filter redacts GSTIN, PAN, phone, Aadhaar-like and ID patterns.

Retention

Document photos are crypto-shredded (data key destroyed, file deleted) 30 days after upload, unless telecom KYC record-keeping needs longer; the verified fields stay encrypted for the contract. Abandoned conversations are purged after 30 days. An hourly job enforces both.

Rights

From the tracker the owner can see and download their data, withdraw any consent and erase their data; identifiers and documents are crypto-shredded. Grievances are answered within the 90 days the Rules allow; we target 7.

Breach response

Tell affected owners without delay; notify the Data Protection Board without delay and send a detailed report within 72 hours (Rule 7). Per-record keys and audit logs limit what any one breach can expose.

Fraud controls

GSTIN checksum and live registry status (22 customers last quarter held a cancelled or suspended GSTIN), cross-document name and address matching, tamper signals, a SIM swap in the last 72 hours on the signatory's number, and a human review queue.

Tested, not just written

The test suite checks that the advisor never sees a raw identifier, that detokenising for the wrong purpose is refused and audited, that withdrawn consent blocks KYC, and that erasure leaves only ciphertext with no key.

Mocked in the prototype: registries, DigiLocker, SIM swap and number verification, masked calling, payments.

In production: India-region hosting (Cloud Run, asia-south1), master key in KMS, processor contracts with every vendor.